

Responsabilidad Institucional en Seguridad de la Información: Evidencia documental y diligencia debida

Institutional Responsibility in Information Security: Documentary evidence and due diligence

AUTOR:

Mariano Enrique Torres Ponce

Abogado y Especialista en Derecho Informático

ORCID id: [0009-0009-6284-3867](https://orcid.org/0009-0009-6284-3867)

RESUMEN

El trabajo examina la seguridad de la información desde una perspectiva que integra derecho, auditoría interna y gestión organizacional. Se parte de la idea de que la protección de los activos informacionales no depende solo de controles operativos, sino de una estructura normativa que defina responsabilidades y conserve evidencia capaz de sostener decisiones. La auditoría interna permite interpretar esa estructura y revela la forma en que políticas, procedimientos y prácticas cotidianas se articulan dentro del funcionamiento real de la institución. El análisis muestra que la claridad documental, la trazabilidad y la consistencia en la ejecución son elementos que influyen de manera directa en la madurez del sistema de seguridad. También se identifican obstáculos frecuentes vinculados con saturación normativa, desactualización documental y ausencia de ciclos de mejora. A partir de estos hallazgos se propone un enfoque de alineación jurídica y auditora que refuerza la coherencia del sistema y mejora la capacidad institucional para actuar con diligencia en escenarios de incertidumbre.

ABSTRACT

This paper examines information security through an integrated perspective that combines legal reasoning, internal auditing and organizational practice. The analysis assumes that effective protection does not depend solely on technical controls but on a coherent normative structure that assigns responsibilities and preserves reliable evidence. Internal auditing provides the vantage point to understand how policies, procedures and day-to-day practices interact within institutional operations. The findings show that documentary clarity, traceability and consistent execution are central elements in determining the maturity of an information security system. The study also identifies structural weaknesses related to normative saturation, outdated documentation and the absence of continuous improvement cycles. Based on these observations, the paper advances an alignment approach that links legal obligations with audit criteria and reinforces the organization's capacity to justify decisions in scenarios marked by uncertainty.

PALABRAS CLAVE

seguridad de la información, auditoría interna, documentación normativa, responsabilidad institucional, evidencia digital, madurez organizacional, gestión del riesgo

KEYWORDS

information security, internal auditing, normative documentation, institutional responsibility, digital evidence, organizational maturity, risk management

ÍNDICE

Resumen / Abstract	1
Palabras clave / Keywords	2
A. Introducción	4
B. Marco teórico y estado del arte	5
B.1. Fundamentos clásicos de la seguridad y su estructura normativa	6
B.2. La función de auditoría interna y el control de las estructuras documentales	6
B.3. Implicancias jurídicas y probatorias del sistema de seguridad	7
B.4. Marcos y guías vigentes en el período analizado	8
C. Auditoría interna y seguridad jurídica	8
C.1. Relación entre marco normativo interno y responsabilidad	8
C.2. Rol de la alta dirección y deber de diligencia	9
C.3. Trazabilidad documental y validez probatoria	9
C.4. Gestión del riesgo y accountability organizacional	10
C.5. Cultura institucional, concientización y capacitación	10
D. Evaluación de controles de seguridad	11
D.1. Control de accesos y segregación de funciones	11
D.2. Gestión de incidentes, respuesta y documentación	11
D.3. Continuidad del negocio y resiliencia organizacional	12
D.4. Seguridad física, ambiental y de proveedores	13
D.5. Recursos humanos, procesos disciplinarios y desvinculación	13
E. Obstáculos y fallas comunes identificadas en auditoría	14
E.1. Saturación normativa y ambigüedad	14
E.2. Falta de alineación entre políticas y práctica real	14
E.3. Documentación desactualizada y riesgo jurídico	15
E.4. Fallas en los ciclos de mejora y en la continuidad de los procesos	16
E.5. Tercerización sin controles suficientes	16
F. Propuesta de alineación jurídica y auditora	17
F.1. Redacción normativa clara y criterios de revisión	17
F.2. Integración del riesgo jurídico, operativo y organizacional	17
F.3. Evidencia, trazabilidad y preservación	18
F.4. Modelo de madurez para la auditoría interna	18
F.5. Recomendaciones para la alta dirección	18
G. Conclusión	19
Bibliografía	20

A. INTRODUCCIÓN

La seguridad de la información se fortaleció como un campo que articula los riesgos tecnológicos, por un lado, con obligaciones jurídicas y formas organizacionales de control. Su desarrollo estuvo impulsado por la necesidad de reducir la incertidumbre generada por sistemas cada vez más interdependientes. Los marcos normativos internacionales contribuyeron a ordenar ese proceso y ofrecieron criterios objetivos para interpretar responsabilidades y expectativas. Por eso, la noción de seguridad dejó de ser una función dispersa y se transformó en un componente estructural del gobierno institucional.

En este contexto, la auditoría interna comienza a ocupar un papel cada vez más relevante en la seguridad de la información. Su función de revisión independiente permite vincular el diseño documental con la práctica cotidiana y muestra la importancia de mantener coherencia entre políticas, procedimientos y controles como señal de madurez institucional. La observación del auditor sobre la asignación de responsabilidades y el comportamiento de los procesos frente a la incertidumbre ofrece una visión concreta del sistema. El análisis de la documentación revela la estructura de obligaciones internas que buscan sostener la protección de los activos informacionales.

El campo jurídico aportó una dimensión decisiva. La seguridad no solo se evalúa en términos operativos. También expresa una forma de responsabilidad institucional. La existencia de criterios claros, la trazabilidad documental y la consistencia en la ejecución configuran un estándar razonable de diligencia. La falta de definiciones o la ausencia de registros comprometen la capacidad de explicar y justificar decisiones. La trazabilidad se convierte en un mecanismo indispensable para reconstruir hechos y para sostener el cumplimiento normativo.

La literatura especializada ha resaltado la importancia de los marcos regulatorios y de las políticas internas como expresión del deber de cuidado organizacional. El desarrollo de estándares internacionales reflejó esta tendencia y consolidó prácticas que integran riesgo, controles y registros formales. Las obras dedicadas a la regulación de la seguridad y al análisis del ciberdelito facilitaron la comprensión de las obligaciones emergentes y de la necesidad de estructuras normativas que permitan sostener decisiones complejas. La interacción entre tecnología, procesos y derecho dejó de ser accesorio y pasó a representar un eje de gobierno institucional.

El enfoque de auditoría interna permite examinar este entramado de manera sistemática. La revisión de los documentos que organizan la seguridad revela no solo el estado del sistema

sino también el grado de compromiso directivo. La cultura institucional influye en la eficacia de las medidas adoptadas y condiciona el cumplimiento real de los controles. La claridad en la asignación de roles, la difusión de las políticas y el mantenimiento del sistema se convierten en elementos que afectan el riesgo y determinan la calidad de la evidencia disponible.

El objetivo de este trabajo es articular una mirada que combine auditoría interna y análisis jurídico para comprender cómo se estructura la seguridad de la información dentro de las organizaciones. El sistema documental, los controles y la cultura institucional se examinan como parte de un entramado que define responsabilidad, coherencia y capacidad de respuesta. Este enfoque permite entender que la seguridad depende tanto de los controles instrumentales como del diseño normativo que orienta la conducta institucional.

B. MARCO TEÓRICO Y ESTADO DEL ARTE

El campo de la seguridad de la información se apoyó en una serie de ideas que no aparecieron de manera ordenada. Surgieron a partir de prácticas dispersas, de problemas concretos y de intentos de las organizaciones por entender fenómenos que avanzaban más rápido que sus propias estructuras. La literatura que acompañó ese proceso ayudó a darle un sentido más claro a lo que, en la práctica, eran esfuerzos aislados por conservar estabilidad. Ese recorrido permitió advertir que la protección de la información no depende solo de soluciones técnicas. Requiere un marco conceptual que permita organizar criterios y que ofrezca una base común para interpretar decisiones. Los estándares internacionales aportaron esa base al proponer métodos que vinculan riesgo, roles y documentación de manera más coherente (International Organization for Standardization [ISO], 2013). Con el tiempo, la seguridad dejó de funcionar como un conjunto de respuestas improvisadas y empezó a consolidarse como un sistema que necesita cierta continuidad conceptual para sostenerse.

Los enfoques técnicos y jurídicos coincidieron en que la seguridad se vuelve más robusta cuando las organizaciones reconocen que los controles no operan en el vacío. Dependen de prácticas, de expectativas internas y de un modo particular de gestionar la información. La literatura técnica señaló que los controles adquieren sentido cuando forman parte de una estructura organizacional que los ubica dentro de procesos estables y conocidos (National Institute of Standards and Technology [NIST], 2013). La producción académica sobre gobernanza reforzó esta lectura al mostrar que la protección de la información no se limita a un conjunto de herramientas, sino que exige una interpretación institucional sostenida en

reglas claras y en criterios consistentes (von Solms, 2005). Desde esa perspectiva, la seguridad se fortalece cuando la organización logra integrar estos elementos en un marco que permita justificar decisiones y demostrar la razonabilidad de sus actos.

B.1. FUNDAMENTOS CLÁSICOS DE LA SEGURIDAD Y SU ESTRUCTURA NORMATIVA

Los principios de confidencialidad, integridad y disponibilidad constituyen el marco conceptual que organiza la disciplina de la seguridad de la información. Estos principios ofrecen un punto de referencia relativamente estable que permite evaluar controles con cierta objetividad. La literatura técnica temprana advirtió que estos conceptos solo resultan operativamente útiles cuando la organización los transforma en reglas claras y en procesos reproducibles que no dependan de interpretaciones cambiantes (Schneier, 2015). Desde una perspectiva jurídica, esta transformación adquiere relevancia adicional. Las obligaciones de seguridad no pueden cumplirse mediante compromisos abstractos. Requieren concreción en políticas específicas, procedimientos documentados y controles verificables que permitan acreditar su aplicación efectiva.

Estudios posteriores mostraron que la seguridad alcanza mayor efectividad cuando existe equilibrio entre tecnología, procesos y cultura institucional (Dhillon, 1997). Este equilibrio resulta particularmente relevante desde el punto de vista de la responsabilidad institucional. Los tribunales no evalúan la diligencia únicamente por la sofisticación técnica de los controles implementados. Evalúan si la organización logró integrar esos controles dentro de una estructura coherente que incluya políticas claras, procesos estables y capacitación efectiva del personal. Las obras dedicadas al análisis de normas internacionales y nacionales de seguridad aportaron claridad sobre cómo se estructura ese lenguaje normativo y sobre cómo se relaciona con las obligaciones internas que asumen las organizaciones (Prandini y Maggiore, 2013). Las discusiones sobre ciberdelito reforzaron esta perspectiva al mostrar que la capacidad para investigar incidentes depende en gran medida de la calidad de la documentación interna y de las garantías que rodean la conservación de evidencia digital relevante (Prandini y Maggiore, 2013).

B.2. LA FUNCIÓN DE AUDITORÍA INTERNA Y EL CONTROL DE LAS ESTRUCTURAS DOCUMENTALES

La auditoría interna incorporó este marco conceptual y lo transformó en un criterio para evaluar el comportamiento institucional. La disciplina auditora parte de una premisa sencilla. La organización solo puede demostrar lo que documenta y solo puede documentar lo que ha

definido que debe hacer. Los estándares profesionales reforzaron esta visión al señalar que la evidencia es el elemento central del trabajo auditor y que la calidad de esa evidencia depende de la consistencia de los documentos que describen procesos y responsabilidades (The Institute of Internal Auditors [IIA], 2017). Investigaciones en comportamiento organizacional mostraron que las políticas solo alcanzan su propósito cuando se integran en la práctica diaria y cuando las personas las internalizan como parte de su actividad normal (Siponen, 2000). La auditoría observa este punto porque muestra el grado de madurez institucional. La distancia entre lo escrito y lo ejecutado revela fallas estructurales que afectan la protección de los activos informacionales.

La literatura sociológica destacó que la seguridad es una construcción colectiva que depende de la forma en que la organización distribuye roles, reconoce riesgos y establece mecanismos de control (Dhillon, 1997). Este enfoque permite entender por qué la auditoría interna presta tanta atención a la redacción de las políticas y a la claridad de los procedimientos. La interpretación de un documento condiciona la interpretación del control. Una política ambigua o desordenada puede producir más incertidumbre que protección. Por eso, la documentación se convierte en una pieza central del análisis auditor.

B.3. IMPLICANCIAS JURÍDICAS Y PROBATORIAS DEL SISTEMA DE SEGURIDAD

La seguridad incorpora una dimensión jurídica que se vuelve evidente cuando la organización necesita reconstruir hechos o explicar decisiones. La literatura sobre evidencia digital remarcó la importancia de contar con registros íntegros, fiables y completos que permitan sostener conclusiones (Casey, 2004). La integridad probatoria no se construye de manera improvisada. Surge de la manera en que la organización gestiona sus documentos y de la estabilidad de los procesos que generan esa información. Estudios jurídicos sobre responsabilidad demostraron que la capacidad para explicar actos depende de la existencia de reglas claras y de la trazabilidad de las decisiones (Hildebrandt, 2015). La literatura en privacidad también aportó elementos para comprender cómo la documentación se transforma en evidencia que permite valorar la diligencia institucional (Solove, 2008). Las obras que abordaron el ciberdelito reforzaron esta idea al mostrar que la ausencia de documentos adecuados dificulta la investigación y genera vacíos probatorios que se traducen en mayores riesgos (Prandini y Maggiore, 2013).

B.4. MARCOS Y GUÍAS VIGENTES EN EL PERÍODO ANALIZADO

Los estándares internacionales ofrecieron un método sistemático para organizar la seguridad y consolidaron una visión cíclica que articula planificación, implementación, monitoreo y mejora continua. Estos marcos entregaron criterios objetivos que facilitan evaluar riesgos, seleccionar controles proporcionales y revisar periódicamente su efectividad real (ISO, 2013). Las guías técnicas de ese período reforzaron la centralidad de la continuidad del negocio, la gestión estructurada de incidentes y, sobre todo, la documentación como herramienta esencial para sostener decisiones y acreditar diligencia (European Union Agency for Network and Information Security [ENISA], 2019). La literatura de auditoría interna aportó un análisis crítico sobre la lógica del control y demostró cómo las organizaciones adoptan estos marcos no solo por cumplimiento formal, sino para fortalecer de verdad su estructura de gobernanza (Power, 1999). Este enfoque logró integrar de manera más clara el análisis de riesgo técnico con el análisis de responsabilidad institucional. La documentación dejó de ser un mero requisito burocrático y se convirtió en el instrumento que orienta acciones, facilita la revisión independiente y permite sostener conclusiones sólidas frente a cualquier cuestionamiento.

C. AUDITORÍA INTERNA Y SEGURIDAD JURÍDICA

La auditoría interna ofrece una mirada que integra lo técnico y lo institucional en un escenario donde la seguridad de la información continúa consolidándose como función estratégica. Los controles requieren una estructura que dé sentido a su aplicación y permita demostrar que la organización actúa con coherencia. Esta estructura se expresa en la documentación interna y en la manera en que los procesos se aplican realmente. La auditoría transforma ese entramado en evidencia sobre el comportamiento institucional, especialmente cuando resulta necesario reconstruir hechos y justificar decisiones.

C.1. RELACIÓN ENTRE MARCO NORMATIVO INTERNO Y RESPONSABILIDAD

El marco normativo interno organiza la seguridad mediante políticas, normas y procedimientos que asignan responsabilidades y describen formas de actuación. Estos documentos cumplen una función que trasciende su contenido técnico. Establecen criterios que orientan la conducta institucional y permiten interpretar cómo la organización entiende sus obligaciones. Sin embargo, cuando esos criterios son ambiguos o cuando coexisten

múltiples fuentes normativas sin jerarquía clara, la responsabilidad se vuelve objeto de disputa.

La relevancia jurídica del marco normativo interno se vuelve especialmente visible cuando la organización debe explicar cómo diseñó, ejecutó y revisó un control. La mera existencia de una política no demuestra su aplicación si los registros no permiten vincular el control declarado con las decisiones y acciones efectivamente realizadas. Esta exigencia no convierte toda desviación operativa en responsabilidad automática. Exige que la institución pueda mostrar los criterios aplicados, los roles asignados, las alertas generadas, las excepciones autorizadas y las medidas adoptadas.

Desde la perspectiva auditora, la documentación debe permitir reconstruir el funcionamiento del sistema sin depender de explicaciones posteriores o de interpretaciones individuales. Los estándares de seguridad y evaluación de controles insisten en la necesidad de integrar políticas, procedimientos, responsabilidades y evidencia dentro de un proceso verificable (ISO, 2013; NIST, 2013). La literatura sobre ciberdelito también muestra que la ausencia de reglas claras y registros adecuados dificulta la identificación de responsabilidades y la reconstrucción de incidentes (Prandini y Maggiore, 2013).

C.2. ROL DE LA ALTA DIRECCIÓN Y DEBER DE DILIGENCIA

La alta dirección establece el tono del sistema de seguridad. El grado de compromiso directivo influye en la calidad del marco documental y en la estabilidad de los controles. Los estándares profesionales insistieron en que la seguridad solo adquiere consistencia cuando la dirección reconoce sus responsabilidades y sostiene procesos de revisión que acompañan la evolución del entorno (IIA, 2017). La literatura jurídica analizó esta cuestión desde la perspectiva del deber de diligencia y mostró que la conducción institucional se evalúa según la razonabilidad de las decisiones adoptadas frente a los riesgos identificados (Hildebrandt, 2015). Investigaciones en regulación de datos destacaron que la dirección tiene un papel central en la construcción de accountability y que esta responsabilidad exige explicaciones claras sobre la forma en que se adoptan medidas de protección (Bygrave, 2014). La auditoría interna observa estos elementos para determinar si la dirección mantiene una conducción efectiva del sistema y si el marco documental refleja ese liderazgo.

C.3. TRAZABILIDAD DOCUMENTAL Y VALIDEZ PROBATORIA

La trazabilidad se vuelve un elemento decisivo cuando la organización necesita reconstruir hechos o justificar acciones. La calidad de los registros condiciona la capacidad para demostrar que un proceso se ejecutó como estaba previsto. La literatura forense remarcó la

importancia de conservar evidencia íntegra, fiable y comprensible para sostener conclusiones basadas en datos verificables (Casey, 2004). La doctrina vinculada a privacidad destacó que la validez probatoria depende de la manera en que se gestionan los documentos y de la estabilidad de los procesos que generan los registros (Solove, 2008). La auditoría interna analiza estos criterios con detenimiento y verifica si los documentos permiten seguir el recorrido de una acción, identificar a los responsables y comprender cómo se aplicaron los procedimientos. La ausencia de trazabilidad afecta la consistencia del sistema y debilita la capacidad institucional para sostener decisiones frente a cuestionamientos.

C.4. GESTIÓN DEL RIESGO Y ACCOUNTABILITY ORGANIZACIONAL

El análisis del riesgo se integró a la seguridad como una forma de ordenar la toma de decisiones. Los marcos técnicos propusieron métodos para identificar amenazas, valorar impactos y seleccionar medidas proporcionales (NIST, 2012). La literatura jurídica vinculó este enfoque con la noción de accountability y mostró que la responsabilidad institucional depende de la capacidad de justificar decisiones y de demostrar que estas surgieron de un proceso razonado (Bygrave, 2002). Investigaciones en comportamiento organizacional señalaron que la gestión del riesgo solo resulta efectiva cuando se articula con prácticas institucionales capaces de sostener controles y de adaptar procesos cuando cambian las condiciones (Dhillon, 1997). La auditoría interna revisa si la organización incorporó estos criterios y si la documentación refleja una integración real entre el análisis de riesgo y los controles que se aplican.

C.5. CULTURA INSTITUCIONAL, CONCIENTIZACIÓN Y CAPACITACIÓN

La cultura institucional influye de manera decisiva en la efectividad de la seguridad. Las políticas pueden estar bien redactadas y los procedimientos pueden describir con precisión cada paso. Sin embargo, estos documentos pierden fuerza cuando no forman parte de la práctica cotidiana. La literatura dedicada al comportamiento organizacional mostró que la actitud de los usuarios determina, en buena medida, la eficacia de los controles (Siponen, 2000). Estudios sobre cultura institucional explicaron que las organizaciones desarrollan patrones de comportamiento que condicionan la forma en que se interpretan las reglas y se aplican los procesos (Schein, 1985). Investigaciones sobre fallas sistémicas demostraron que muchos incidentes se originan en errores humanos que la organización no logró anticipar ni mitigar (Reason, 1990). La auditoría interna analiza estos factores porque revelan el grado de madurez del sistema y la medida en que la cultura instaure hábitos favorables a la seguridad.

D. EVALUACIÓN DE CONTROLES DE SEGURIDAD

La auditoría interna interpreta los controles como piezas que expresan el modo en que la organización protege la información. Cada control refleja decisiones previas sobre riesgo, responsabilidades y capacidad operativa. Dado que la seguridad no puede sostenerse solo con configuraciones aisladas, la literatura técnica mostró que los controles pierden eficacia cuando se aplican sin un marco que los organice o cuando carecen de documentación que permita entender su propósito (ISO, 2013). La auditoría trabaja sobre estos elementos y examina la consistencia entre las políticas, los procedimientos y las prácticas reales. La revisión no se limita al funcionamiento técnico del control. También incluye una lectura más amplia que conecta decisiones directivas, cultura institucional y calidad de la evidencia disponible. La coherencia entre estos factores define el grado de madurez del sistema y la capacidad de la organización para sostener sus decisiones frente a escenarios de incertidumbre.

D.1. CONTROL DE ACCESOS Y SEGREGACIÓN DE FUNCIONES

El control de accesos representa uno de los núcleos clásicos de la seguridad. Su función consiste en regular quién puede hacer qué dentro de los sistemas y en establecer límites que preserven la información. La literatura señaló que la consistencia en este punto depende de la claridad del modelo de roles y de la capacidad para mantener registros que permitan reconstruir cada cambio en los permisos otorgados (ISO, 2013). Estudios sobre riesgo organizacional mostraron que la acumulación de privilegios en una misma persona genera vulnerabilidades que pueden comprometer la integridad del sistema (Power, 1999). Investigaciones sobre errores humanos demostraron que muchas fallas en los accesos surgen de prácticas que no fueron supervisadas de manera adecuada o de decisiones aisladas que no respondieron a criterios documentados (Reason, 1990).

La auditoría interna analiza cómo se asignan los accesos y cómo se mantienen a lo largo del tiempo. Revisa procesos de altas, modificaciones y bajas. Verifica si los privilegios se ajustan a las responsabilidades reales y si los registros permiten reconstruir el historial de los permisos otorgados. La calidad del control depende de la combinación entre claridad documental, supervisión constante y cultura institucional orientada a mantener la coherencia entre rol y acceso.

D.2. GESTIÓN DE INCIDENTES, RESPUESTA Y DOCUMENTACIÓN

Los incidentes revelan el estado real del sistema de seguridad. El modo en que la organización responde a un evento adverso expresa la calidad de sus procesos y el grado de

claridad del marco documental. Un fallo de la Corte de Apelaciones de Santiago (2017) sobre phishing bancario ilustra esta dinámica. Una clienta recibió un correo fraudulento que solicitaba actualizar datos de seguridad. Ingresó credenciales y códigos de su dispositivo de autenticación. Minutos después se ejecutaron tres operaciones no autorizadas por \$3.558.570. La afectada solicitó bloqueo inmediato, denunció ante la policía y objetó las transacciones.

El banco argumentó que su sistema no había sido vulnerado y que las operaciones cumplían todas las validaciones técnicas. La clienta demostró mediante documentación que había actuado inmediatamente al detectar la anomalía. El tribunal consideró que la entidad debía mantener mecanismos de detección de patrones fraudulentos conforme a la regulación de la superintendencia local, lo que implicaba algo más que validar credenciales formalmente correctas. La ausencia de estos controles fue interpretada como incumplimiento del deber de cuidado institucional (Corte de Apelaciones de Santiago, 2017).

La capacidad de reconstrucción dependió de la documentación conservada por ambas partes. Registros de transacciones, comunicaciones, denuncias y logs del sistema permitieron establecer la secuencia temporal completa. Los marcos técnicos han señalado que la respuesta ante incidentes requiere procedimientos definidos que organicen la identificación de eventos, su contención y la preservación de evidencia (NIST, 2012). La literatura forense destacó que la integridad de los registros condiciona la posibilidad de sostener conclusiones verificables (Casey, 2004). La auditoría interna examina si la organización mantiene procesos ordenados que generen documentación suficiente para reconstruir hechos y sostener decisiones bajo presión.

D.3. CONTINUIDAD DEL NEGOCIO Y RESILIENCIA ORGANIZACIONAL

La continuidad del negocio se vincula con la necesidad de sostener operaciones esenciales frente a eventos que afectan la disponibilidad de los sistemas. La literatura especializada mostró que este análisis requiere comprender cuáles son los procesos críticos, cuáles son los impactos derivados de una interrupción y cuáles son los recursos necesarios para recuperar la actividad dentro de plazos razonables (ENISA, 2019). Estudios sobre cultura institucional señalaron que la resiliencia depende tanto de la planificación como de la manera en que la organización internaliza procedimientos y mantiene capacidad para adaptarse en situaciones adversas (Schein, 1985).

La auditoría interna revisa si la organización realizó análisis de impacto, si mantiene planes vigentes y si ejecuta pruebas periódicas que permitan verificar la efectividad de esos planes. También analiza si los resultados de estas pruebas se documentan y si generan acciones de

mejora. La continuidad del negocio se transforma así en un indicador que muestra el grado de estabilidad del sistema de seguridad y la capacidad institucional para sostener operaciones en escenarios de incertidumbre.

D.4. SEGURIDAD FÍSICA, AMBIENTAL Y DE PROVEEDORES

La seguridad física y ambiental conserva un papel relevante dentro de la disciplina. La literatura técnica señaló que la protección de los activos depende tanto de los controles lógicos como de las medidas destinadas a regular el acceso físico a las instalaciones y a conservar condiciones adecuadas para el funcionamiento de los equipos (ISO, 2013). La auditoría evalúa si la organización mantiene estos controles de manera consistente y si los documentos internos describen con precisión las responsabilidades asociadas.

La relación con proveedores introduce riesgos adicionales. Estudios de riesgo organizacional advirtieron que la tercerización sin controles adecuados puede generar vulnerabilidades que afectan la seguridad general del sistema (Power, 1999). Las guías técnicas destacaron que los contratos deben incluir criterios que regulen la protección de la información y que permitan verificar el cumplimiento de las obligaciones asumidas por los terceros (NIST, 2014). La auditoría interna analiza estos contratos y revisa si la organización mantiene registros de seguimiento que permitan evaluar la calidad del servicio y la coherencia entre riesgos y controles aplicados.

D.5. RECURSOS HUMANOS, PROCESOS DISCIPLINARIOS Y DESVINCULACIÓN

El comportamiento de las personas constituye un factor determinante en la seguridad. Las políticas de seguridad pueden ser correctas y los procedimientos pueden estar bien definidos. Sin embargo, la efectividad del sistema depende del modo en que los equipos incorporan estas reglas en sus prácticas diarias. La literatura sobre comportamiento organizacional mostró que la capacitación continua y la claridad normativa influyen en la forma en que las personas ejecutan sus tareas (Siponen, 2000). Estudios sobre fallas humanas demostraron que muchos incidentes se originan en hábitos que no fueron corregidos o en desconocimiento de procedimientos básicos (Reason, 1990).

La auditoría interna revisa procesos de ingreso, formación y desvinculación. Observa la existencia de verificaciones previas, programas de concientización y mecanismos disciplinarios que permitan abordar incumplimientos. También examina cómo se gestionan los accesos cuando un empleado deja la organización y cómo se documenta la recuperación de activos. La coherencia entre estos procesos revela la capacidad institucional para reducir

riesgos asociados al factor humano y para sostener prácticas de protección que acompañen la actividad diaria.

E. OBSTÁCULOS Y FALLAS COMUNES IDENTIFICADAS EN AUDITORÍA

La auditoría interna permite observar dónde se debilita la seguridad y por qué ciertas estructuras documentales pierden efectividad con el tiempo. Estas fallas suelen surgir de prácticas cotidianas que se desalinean del marco normativo o de decisiones que se acumulan sin la revisión necesaria. La literatura técnica y organizacional señaló que la seguridad se debilita cuando los documentos dejan de orientar la operación y los controles se aplican de manera irregular (ISO, 2013). Las observaciones de auditoría confirman que muchas vulnerabilidades se originan en problemas estructurales que se consolidan gradualmente y deterioran la capacidad institucional para conservar evidencia fiable. Esta dinámica exige una intervención más profunda que un ajuste operativo aislado.

E.1. SATURACIÓN NORMATIVA Y AMBIGÜEDAD

La saturación documental es una de las fallas más frecuentes. La organización suma políticas, normas y procedimientos que intentan cubrir todos los escenarios posibles. Este crecimiento desordenado genera un sistema difícil de interpretar. Los documentos se superponen, se contradicen o dejan vacíos que habilitan lecturas incompatibles. La literatura dedicada a la gobernanza de la seguridad advirtió que el exceso de normas puede producir el efecto contrario al buscado y debilitar la capacidad de control (von Solms, 2005). Estudios técnicos señalaron que la ambigüedad en la redacción genera incertidumbre en la aplicación de los controles y favorece decisiones que no responden a criterios uniformes (Schneier, 2015). La auditoría interna interpreta este escenario como una señal de deterioro institucional porque revela una estructura normativa que perdió coherencia.

E.2. FALTA DE ALINEACIÓN ENTRE POLÍTICAS Y PRÁCTICA REAL

La falta de alineación entre políticas y práctica aparece cuando las obligaciones descritas en los documentos no se ejecutan de manera consistente. Esta brecha deteriora la credibilidad del sistema porque transforma los controles en declaraciones formales sin consecuencias operativas. Los equipos internalizan que el incumplimiento carece de efectos reales y que las reglas escritas funcionan como referencia nominal sin impacto en la actividad cotidiana.

Las investigaciones sobre comportamiento organizacional mostraron que esta desconexión surge cuando las políticas no se integran en los procesos diarios y cuando los responsables no

las reconocen como parte natural de su tarea (Schein, 1985). Los marcos técnicos señalaron que un control bien diseñado pierde efectividad si su aplicación depende de decisiones improvisadas o si carece de mecanismos que aseguren su ejecución consistente (ISO, 2013). La distancia entre documento y práctica genera dos problemas simultáneos. Primero, la organización carece del control que supuso haber implementado. Segundo, pierde capacidad para demostrar diligencia porque la evidencia documental contradice la realidad operativa.

La auditoría interna identifica estos desajustes porque revelan riesgo estructural. Una política que no se aplica anticipa fallas posteriores y limita la posibilidad de sostener decisiones frente a cuestionamientos. La contradicción entre lo establecido y lo ejecutado debilita tanto la protección efectiva de los activos informacionales como la capacidad institucional para justificar sus actos mediante evidencia suficiente.

E.3. DOCUMENTACIÓN DESACTUALIZADA Y RIESGO JURÍDICO

La falta de actualización se convierte en un problema crítico cuando los documentos dejan de reflejar el estado real de la organización. Un procedimiento obsoleto no solo afecta la eficacia operativa, sino que también deteriora la capacidad jurídica para explicar decisiones y acreditar diligencia. La documentación genérica o desfasada impide determinar qué controles operaban, cómo estaban configurados y qué criterios guiaron la respuesta institucional. La brecha entre el texto formal y la práctica real transforma el documento en una evidencia débil o incluso contradictoria.

La literatura sobre responsabilidad y protección de datos relaciona la diligencia con la capacidad de justificar decisiones mediante reglas comprensibles, procesos estables y registros coherentes (Bygrave, 2014; Hildebrandt, 2015). Los marcos técnicos, por su parte, establecen ciclos de evaluación y actualización destinados a evitar que los controles pierdan correspondencia con el riesgo y con la operación efectiva (NIST, 2012; NIST, 2014).

La auditoría interna identifica estos desfases al comparar la documentación vigente con la evidencia de ejecución. Un documento obsoleto revela un proceso que perdió conducción y dejó de acompañar la evolución del entorno. Esa distancia debilita tanto la protección de los activos informacionales como la capacidad institucional para sostener sus decisiones frente a cuestionamientos posteriores.

E.4. FALLAS EN LOS CICLOS DE MEJORA Y EN LA CONTINUIDAD DE LOS PROCESOS

La seguridad necesita ciclos de revisión que permitan ajustar controles y adoptar medidas correctivas. La ausencia de estos ciclos debilita la capacidad institucional para adaptarse. Investigaciones sobre resiliencia mostraron que las organizaciones que no revisan sus procesos pierden capacidad para enfrentar eventos adversos y tienden a repetir errores conocidos (Schein, 1985). Las guías especializadas remarcaron la importancia de conservar registros que documenten pruebas, resultados y acciones de mejora (ENISA, 2019). La auditoría interna analiza estos elementos para determinar si el sistema mantiene una dinámica de mejora o si se volvió estático. Las fallas en este punto revelan una estructura que conserva documentos, pero no conserva aprendizaje.

E.5. TERCERIZACIÓN SIN CONTROLES SUFICIENTES

La tercerización introduce actores externos cuyas prácticas pueden no alinearse con el marco normativo interno. Esta desalineación genera vulnerabilidades que permanecen inadvertidas hasta que se materializa un incidente o hasta que la auditoría solicita evidencia de cumplimiento. Los contratos suelen establecer compromisos genéricos sin especificar cómo se verificarán ni qué evidencia deberá aportar el tercero para acreditar que cumple las obligaciones asumidas.

Los estudios sobre riesgo organizacional señalaron que la falta de controles sobre proveedores incrementa la exposición institucional porque transfiere actividades críticas sin transferir responsabilidades de manera proporcional (Power, 1999). Las guías técnicas indicaron que la gestión de terceros requiere mecanismos de evaluación continua, cláusulas contractuales que definan obligaciones verificables y procedimientos de supervisión que permitan detectar desviaciones (NIST, 2014). Muchas organizaciones carecen de estos elementos y dependen de servicios esenciales sin capacidad efectiva de control sobre aspectos que consideran críticos para la seguridad de la información.

La auditoría interna examina si la institución mantiene trazabilidad sobre las obligaciones asumidas por proveedores y si conserva registros que permitan demostrar supervisión efectiva. La ausencia de controles contractuales verificables, de procesos de seguimiento documentados o de evidencia sobre el cumplimiento de compromisos críticos limita la capacidad institucional para sostener que actuó con diligencia cuando un proveedor genera un incidente que afecta la protección de los activos informacionales.

F. PROPUESTA DE ALINEACIÓN JURÍDICA Y AUDITORA

El análisis de los controles y de la estructura documental muestra que la seguridad de la información depende de decisiones que deben sostenerse en el tiempo y que requieren un equilibrio entre claridad normativa, madurez organizacional y capacidad de revisión. Como estos elementos no siempre evolucionan de manera uniforme, la auditoría interna permite observar cómo se articulan y reconocer patrones que pueden transformarse en líneas de mejora. La propuesta desarrollada en esta sección busca reforzar ese equilibrio mediante un enfoque que integre criterios jurídicos, técnicos y organizacionales. No se trata de sumar documentos, sino de fortalecer la coherencia del sistema y asegurar que los textos normativos expresen prácticas reales y sostenibles.

F.1. REDACCIÓN NORMATIVA CLARA Y CRITERIOS DE REVISIÓN

La claridad documental constituye un punto de partida indispensable. Una política bien redactada reduce la incertidumbre y facilita la comprensión de las obligaciones. La literatura técnica subrayó la importancia de contar con marcos normativos que describan procesos sin ambigüedades y que definan responsabilidades de manera comprensible (ISO, 2013). La experiencia de auditoría confirma esta idea. Los documentos que expresan decisiones con lenguaje directo permiten verificar acciones y sostener conclusiones. La organización necesita un proceso de revisión que acompañe la evolución operativa y que permita ajustar los documentos cuando cambian las condiciones. La actualización periódica evita desfases y refuerza la correspondencia entre documento y práctica.

F.2. INTEGRACIÓN DEL RIESGO JURÍDICO, OPERATIVO Y ORGANIZACIONAL

La gestión del riesgo se fortalece cuando integra dimensiones jurídicas, operativas y organizacionales. Los marcos técnicos propusieron métodos para identificar amenazas y valorar impactos que permiten ordenar la toma de decisiones (NIST, 2012). La literatura jurídica señaló que la responsabilidad institucional requiere justificar actos y demostrar que las decisiones surgieron de un análisis razonado (Bygrave, 2014). Los estudios en comportamiento organizacional mostraron que la eficacia del riesgo depende de la capacidad para integrar criterios técnicos con prácticas internas que sostengan los controles y acompañen el funcionamiento real de la institución (Dhillon, 1997). La auditoría interna puede reforzar esta integración revisando si el análisis de riesgo se refleja en los documentos, si orienta la asignación de recursos y si se traduce en controles que acompañan la operación

con la estabilidad necesaria para sostener decisiones incluso en momentos de presión y dinamismo institucional creciente.

F.3. EVIDENCIA, TRAZABILIDAD Y PRESERVACIÓN

La evidencia constituye el sustento del análisis auditor y el soporte de la responsabilidad institucional. La literatura forense remarcó la necesidad de conservar registros íntegros y de documentar procesos que permitan reconstruir hechos con precisión (Casey, 2004). La doctrina vinculada a la privacidad sostuvo que la validez probatoria depende de la estabilidad de estos registros y de la coherencia entre procedimientos y evidencia (Solove, 2008). La organización necesita prácticas de trazabilidad que permitan seguir el recorrido de cada acción y que garanticen que los registros se generen y se mantengan de manera consistente. La auditoría interna puede reforzar estas prácticas señalando vacíos documentales y promoviendo procesos que aseguren la integridad de la información.

F.4. MODELO DE MADUREZ PARA LA AUDITORÍA INTERNA

La madurez del sistema de seguridad se evalúa a partir de la correspondencia entre políticas, prácticas y evidencia. La literatura organizacional mostró que las instituciones consolidadas mantienen procesos estables y criterios que guían decisiones en escenarios diversos (Schein, 1985). Las guías técnicas señalaron que la madurez se expresa en la capacidad para sostener controles, revisar procedimientos y adaptar medidas cuando cambian las condiciones (ENISA, 2019). La auditoría interna puede utilizar este enfoque para identificar el lugar que ocupa la organización dentro de ese continuo y para formular recomendaciones que permitan avanzar hacia un estado más consistente. La revisión de estos elementos no implica un diagnóstico rígido. Representa una herramienta para orientar mejoras graduales y sostenidas.

F.5. RECOMENDACIONES PARA LA ALTA DIRECCIÓN

El compromiso directivo condiciona la calidad del sistema de seguridad. La literatura en auditoría destacó que la dirección influye de manera directa en la asignación de recursos, en la estabilidad de los procesos y en la forma en que se interpretan las obligaciones internas (IIA, 2017). La responsabilidad institucional exige que las decisiones acompañen el análisis de riesgo y que los documentos expresen criterios que puedan sostenerse frente a cuestionamientos. La dirección puede fortalecer este proceso consolidando espacios de revisión, promoviendo la actualización documental y fomentando una cultura que incorpore la seguridad en las prácticas diarias. La auditoría interna puede colaborar con este objetivo señalando vacíos, recomendando ajustes y aportando evidencia que permita orientar

decisiones. Este trabajo conjunto refuerza la coherencia del sistema y mejora la capacidad institucional para enfrentar incidentes y justificar acciones.

G. CONCLUSIÓN

El análisis desarrollado muestra un patrón institucional consistente. La existencia formal de políticas, procedimientos o certificaciones no sustituye la evidencia de que los controles fueron ejecutados, revisados y actualizados. La diligencia se vuelve demostrable cuando la organización puede reconstruir sus decisiones mediante registros verificables y relacionarlos con las responsabilidades previamente definidas.

El precedente chileno examinado ilustra la distancia que puede existir entre una validación técnica formal y una respuesta institucional suficiente. La Corte de Apelaciones de Santiago consideró relevantes las deficiencias del sistema de seguridad del banco frente a operaciones fraudulentas, aun cuando las credenciales utilizadas hubieran superado validaciones ordinarias (Corte de Apelaciones de Santiago, 2017). El valor del caso para este trabajo reside en que la seguridad se evaluó como un sistema de controles y no como una única comprobación aislada.

La misma dificultad aparece en la práctica cotidiana de empresas privadas y organismos públicos. Se acumulan manuales que no se consultan, se aprueban procedimientos que no se aplican y se archivan evidencias sin una revisión periódica. La existencia formal del documento se confunde entonces con su efectividad real. La documentación protege cuando refleja con precisión la operación, asigna responsabilidades comprensibles y se mantiene vinculada con la evidencia de ejecución.

La madurez en seguridad de la información no consiste en multiplicar normas ni en acumular certificados. Consiste en documentar lo necesario con claridad, ejecutar de manera consistente lo definido y conservar evidencia suficiente de esa ejecución. La integración entre derecho, auditoría y gestión organizacional permite sostener esa correspondencia y mejora la capacidad institucional para actuar con diligencia en escenarios de incertidumbre.

BIBLIOGRAFÍA

- Bygrave, L. A. (2002). *Data protection law: Approaching its rationale, logic and limits*. Kluwer Law International.
- Bygrave, L. A. (2014). *Data privacy law: An international perspective*. Oxford University Press.
<https://doi.org/10.1093/acprof:oso/9780199675555.001.0001>
- Casey, E. (2004). *Digital evidence and computer crime: Forensic science, computers, and the Internet* (2nd ed.). Academic Press.
- Corte de Apelaciones de Santiago. (2017, 21 de septiembre). Nannig Tuchia con Banco de Chile, Recurso de Protección, Rol N.º 44.191-2017. <https://www.jurischile.com/2017/09/se-acoge-recurso-contrabanco.html>
- Dhillon, G. (1997). *Managing information system security*. Macmillan.
<https://doi.org/10.1007/978-1-349-14454-9>
- European Union Agency for Network and Information Security. (2019). *ENISA threat landscape report 2018*. <https://www.enisa.europa.eu/publications/enisa-threat-landscape-report-2018>
- Hildebrandt, M. (2015). *Smart technologies and the end(s) of law: Novel entanglements of law and technology*. Edward Elgar Publishing.
- Institute of Internal Auditors. (2017). *International standards for the professional practice of internal auditing*. <https://www.theiia.org/en/content/standards/international-standards-for-the-professional-practice-of-internal-auditing/>
- International Organization for Standardization. (2013). *ISO/IEC 27001:2013 Information technology - Security techniques - Information security management systems - Requirements*. <https://www.iso.org/standard/54534.html>
- National Institute of Standards and Technology. (2012). *Guide for conducting risk assessments* (NIST SP 800-30 Rev. 1). <https://doi.org/10.6028/NIST.SP.800-30r1>
- National Institute of Standards and Technology. (2013). *Security and privacy controls for federal information systems and organizations* (NIST SP 800-53 Rev. 4).
<https://csrc.nist.gov/pubs/sp/800/53/r4/final>
- National Institute of Standards and Technology. (2014). *Assessing security and privacy controls in federal information systems and organizations: Building effective assessment plans* (NIST SP 800-53A Rev. 4). <https://csrc.nist.gov/pubs/sp/800/53/a/r4/final>
- Power, M. (1999). *The audit society: Rituals of verification*. Oxford University Press.
<https://doi.org/10.1093/acprof:oso/9780198296034.001.0001>
- Prandini, P., & Maggiore, M. (2013). *Ciberdelito en América Latina y el Caribe: Una visión desde la sociedad civil*. Proyecto AMPARO.
- Reason, J. (1990). *Human error*. Cambridge University Press.
<https://doi.org/10.1017/CBO9781139062367>

- Schein, E. H. (1985). *Organizational culture and leadership: A dynamic view*. Jossey-Bass.
- Schneier, B. (2015). *Data and Goliath: The hidden battles to collect your data and control your world*. W. W. Norton.
- Siponen, M. T. (2000). A conceptual foundation for organizational information security awareness. *Information Management & Computer Security*, 8(1), 31-41.
<https://doi.org/10.1108/09685220010371394>
- Solove, D. J. (2008). *Understanding privacy*. Harvard University Press.
- von Solms, B. (2005). Information security governance: COBIT or ISO 17799 or both? *Computers & Security*, 24(2), 99-104. <https://doi.org/10.1016/j.cose.2005.02.002>